



Universidad Santo Tomás, Seccional Tunja

Facultad de Ingeniería de Sistemas

Burp Suite

Análisis de Tráfico HTTP/HTTPS

Objetivo: <https://latinoamericacomparte.com>

Estudiante: **Juan Diego Velasco Quintero**

Asignatura: Seguridad Informática / Ciberseguridad

Fecha: Tunja, 20 de mayo de 2026

Herramienta: Burp Suite Community Edition v2026.2.3

Entorno: Kali Linux

Documento generado para fines académicos — entorno controlado y autorizado.

Cumplimiento de la Ley 1273 de 2009 (Colombia).

Índice

1. Descripción de la Herramienta	2
2. Módulo 1 — Proxy / Intercept	2
2.1. Descripción	2
2.2. Captura del laboratorio	2
2.3. Cabeceras capturadas	3
3. Módulo 2 — HTTP History	3
3.1. Descripción	3
3.2. Captura del laboratorio	4
3.3. Peticiones destacadas	4
4. Módulo 3 — Repeater (Solicitud manual)	5
4.1. Descripción	5
4.2. Captura del laboratorio	5
4.3. Detalle de la solicitud en Repeater	5
5. Módulo 4 — Repeater con Respuesta del Servidor	6
5.1. Descripción	6
5.2. Captura del laboratorio	7
5.3. Análisis de cabeceras de seguridad en la respuesta	7
6. Resumen de Hallazgos	8
7. Conclusión	8

Descripción de la Herramienta

Burp Suite es una plataforma integrada para pruebas de seguridad en aplicaciones web, desarrollada por PortSwigger. Actúa como un **proxy de interceptación** situado entre el navegador y el servidor, capturando y permitiendo analizar o modificar el tráfico HTTP/HTTPS en tiempo real.

Desarrollador	PortSwigger Ltd.
Versión usada	Burp Suite Community Edition v2026.2.3
Plataforma	Kali Linux (x86_64)
Objetivo	https://latinoamericacomparte.com
Módulos usados	Proxy · HTTP History · Repeater

Sus módulos principales permiten: interceptar y reenviar peticiones (**Proxy**), revisar el historial completo del tráfico (**HTTP History**), repetir y modificar solicitudes manualmente (**Repeater**), y realizar ataques automatizados de fuzzing (**Intruder**).

Módulo 1 — Proxy / Intercept

► Descripción

El módulo **Proxy** con *Intercept on* detiene cada petición antes de que llegue al servidor, permitiéndole al analista inspeccionarla, modificarla o descartarla. Es el punto de entrada del análisis en Burp Suite.

► Captura del laboratorio

La siguiente imagen muestra el panel Intercept activo durante la navegación en latinoamericacomparte.com. En el panel inferior se puede leer la petición GET interceptada hacia fonts.googleapis.com, con todas sus cabeceras HTTP/2. En el historial se observan múltiples peticiones GET a rutas de imágenes del sitio (`/img/EQUIPO%20DE%20TRABAJO/`, `/img/MENTORES/`, `/img/COACHES/`).

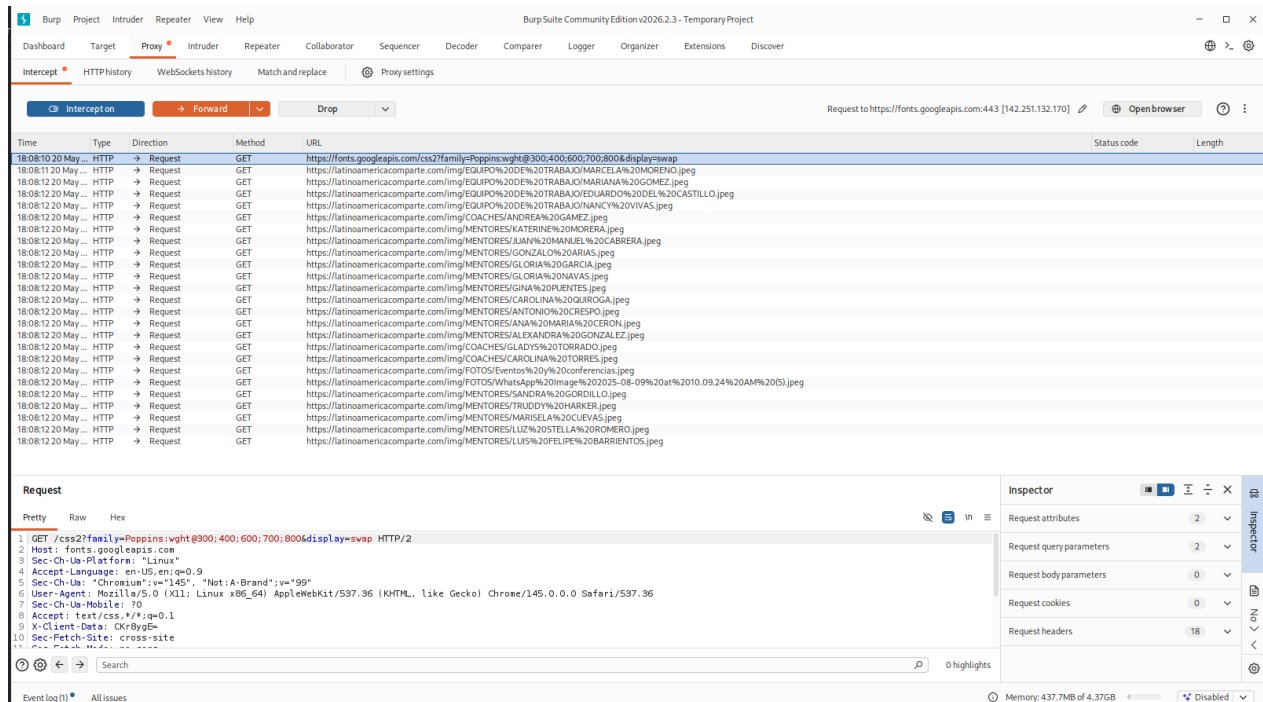


Figura 1: Burp Suite — Proxy Intercept activo sobre latinoamericacomparte.com. Se aprecia la petición GET interceptada a fonts.googleapis.com:443 y el listado de recursos de imagen cargados por el sitio. El Inspector lateral muestra 18 cabeceras de la solicitud.

► Cabeceras capturadas

Cabecera	Valor observado
Host	fonts.googleapis.com
User-Agent	Mozilla/5.0 (X11; Linux x86_64) Chrome/145.0.0.0
Sec-Ch-Ua-Platform	"Linux"
Accept-Language	en-US,en;q=0.9
Accept	text/css,*/*;q=0.1
Sec-Fetch-Site	cross-site
X-Client-Data	CKr8ygE=

Hallazgo: El sitio carga fuentes desde fonts.googleapis.com (CDN externo de Google) con encabezado **Sec-Fetch-Site: cross-site**. Esto introduce una dependencia de terceros sin *Subresource Integrity* (SRI) verificable, lo que podría permitir la sustitución maliciosa de la fuente en un escenario de compromiso del CDN.

Módulo 2 — HTTP History

► Descripción

El panel **HTTP History** registra todo el tráfico que ha pasado por el proxy, con o sin intercepción activa. Permite filtrar, ordenar y analizar cada solicitud por host, método, código de respuesta, tipo MIME,

extensión y tiempo.

► Captura del laboratorio

La imagen siguiente muestra el historial filtrado (ocultando CSS e imágenes) del tráfico capturado durante la navegación. Se identifican dos dominios principales: **latinoamericacomparte.com** y **colombiacomparte.com**, ambos respondiendo con 200 OK.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	IP	Cookies	Time	Listener port	Start respons...
1	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error 404 (Not Found)!!1		✓	142.251.153.119		17:55:59.20 M...	8080	104
2	https://latinoamericacomparte.com	GET	/			200	136239	HTML		Latinoamérica Compa...		✓	64.202.187.143		17:56:04.20 M...	8080	212
77	https://latinoamericacomparte.com	GET	/			200	136239	HTML		Latinoamérica Compa...		✓	64.202.187.143		17:57:02.20 M...	8080	226
152	https://latinoamericacomparte.com	GET	/			200	136239	HTML		Latinoamérica Compa...		✓	64.202.187.143		17:59:08.20 M...	8080	232
247	https://latinoamericacomparte.com	GET	/			200	136239	HTML		Latinoamérica Compa...		✓	64.202.187.143		18:02:33.20 M...	8080	239
342	https://colombiacomparte.com	GET	/			200	279073	HTML		Colombia comparte		✓	192.124.249.102		18:03:21.20 M...	8080	72
498	https://colombiacomparte.com	POST	/wp-admin/admin-ajax.php?action=hu...		✓	200	800	JSON	php			✓	192.124.249.102		18:03:30.20 M...	8080	4134
528	https://colombiacomparte.com	GET	/wp-json/sliderrevolution/sliders/?tse...		✓	200	9239	JSON				✓	192.124.249.102		18:03:34.20 M...	8080	14984
529	https://colombiacomparte.com	GET	/wp-json/sliderrevolution/sliders/?tse...		✓	200	7359	JSON				✓	192.124.249.102		18:03:34.20 M...	8080	14946
531	https://colombiacomparte.com	GET	/			200	279073	HTML		Colombia comparte		✓	192.124.249.102		18:03:42.20 M...	8080	81
567	https://colombiacomparte.com	GET	/wp-json/sliderrevolution/sliders/?tse...		✓	200	9239	JSON				✓	192.124.249.102		18:03:45.20 M...	8080	14421
568	https://colombiacomparte.com	GET	/wp-json/sliderrevolution/sliders/?tse...		✓	200	7359	JSON				✓	192.124.249.102		18:03:45.20 M...	8080	14642
569	https://colombiacomparte.com	POST	/wp-admin/admin-ajax.php?action=hu...		✓	200	800	JSON	nhn			✓	192.124.249.102		18:03:45.20 M...	8080	17399

Figura 2: HTTP History de Burp Suite con filtro activo (*Hiding CSS and image content; hiding specific extensions*). Se observan peticiones a **latinoamericacomparte.com** (IP: 64.202.187.143) y a **colombiacomparte.com** (IP: 192.124.249.102), incluyendo endpoints de WordPress como `/wp-admin/admin-ajax.php` y `/wp-json/sliderrevolution/sliders/`.

► Peticiones destacadas

#	Host	Método	Cód.	Observación
2	latinoamericacomparte.com	GET	200	Pág. principal; 136,239 bytes HTML
77	latinoamericacomparte.com	GET	200	Recarga; mismo tamaño
342	colombiacomparte.com	GET	200	Sitio hermano; 279,073 bytes HTML
498	colombiacomparte.com	POST	200	<code>/wp-admin/admin-ajax.php</code> ; JSON
529	colombiacomparte.com	GET	200	<code>/wp-json/sliderrevolution/</code>
1	www.google.com	GET	404	Warmup; recurso no encontrado

Hallazgos críticos:

1. La URL `/wp-admin/admin-ajax.php` de `colombiacomparte.com` confirma el uso de **WordPress** como CMS. Este endpoint es un vector frecuente de ataques si no está correctamente protegido.
2. La IP `192.124.249.102` para `colombiacomparte.com` difiere de la IP `64.202.187.143` de `latinoamericacomparte.com`, lo que indica infraestructuras separadas bajo la misma organización.
3. El plugin **Slider Revolution** (`/wp-json/sliderrevolution/`) ha tenido CVEs críticos históricamente (ejecución remota de código en versiones antiguas).

Módulo 3 — Repeater (Solicitud manual)**Descripción**

El módulo **Repeater** permite tomar una solicitud interceptada, modificarla manualmente y reenviarla al servidor cuantas veces sea necesario para observar distintas respuestas. Es fundamental para pruebas de manipulación de parámetros y cabeceras.

Captura del laboratorio

La imagen muestra la solicitud enviada al Repeater desde el Proxy Intercept. Se trata de un GET a `fonts.googleapis.com` con destino `/css2?family=Poppins:wght@300;400;600;700;800&display=swap`. El Inspector lateral detalla los 18 encabezados HTTP/2 de la petición, incluyendo el `referer`: `https://latinoamericacomparte.com` que confirma el origen de la solicitud.

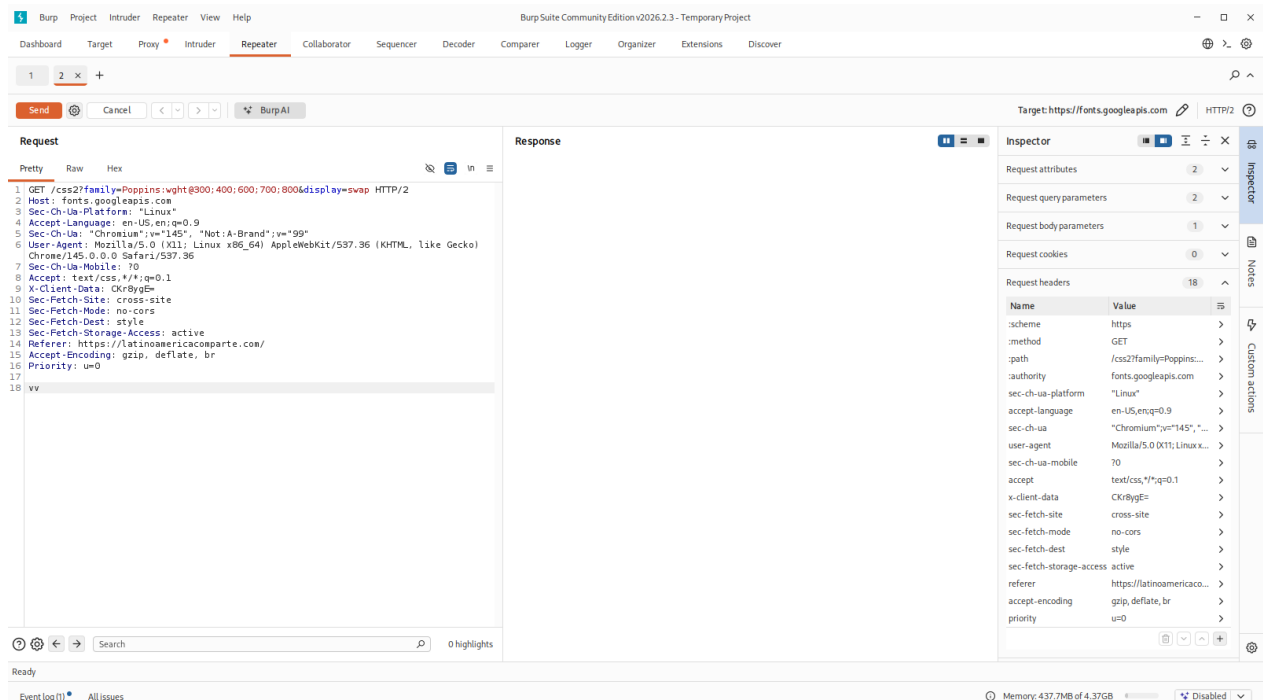


Figura 3: Módulo Repeater — solicitud GET a `fonts.googleapis.com` enviada desde `latinoamericacomparte.com`. Se aprecian los 18 encabezados HTTP/2, el campo `referer` y los parámetros de la fuente Poppins. El panel de respuesta aún no ha sido enviado (estado *Ready*).

Detalle de la solicitud en Repeater

```
GET /css2?family=Poppins:wght@300;400;600;700;800&display=swap HTTP/2
Host: fonts.googleapis.com
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: en-US,en;q=0.9
Sec-Ch-Ua: "Chromium";v="145", "Not:A-Brand";v="99"
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
Accept: text/css,*/*;q=0.1
X-Client-Data: CKr8ygE=
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: style
Sec-Fetch-Storage-Access: active
Referer: https://latinoamericacomparte.com/
Accept-Encoding: gzip, deflate, br
Priority: u=0
```

Análisis: La cabecera **Referer** confirma que latinoamericacomparte.com realiza una petición cross-site a Google Fonts al cargar cada página. Un atacante con capacidad de man-in-the-middle sobre la conexión al CDN podría inyectar CSS malicioso. La ausencia de SRI en la etiqueta <link> impide que el navegador valide la integridad del recurso recibido.

Módulo 4 — Repeater con Respuesta del Servidor

► Descripción

Esta sección documenta una petición **POST** a colombiacomparte.com capturada y reenviada desde el Repeater, con su respuesta completa del servidor. Permite analizar las cabeceras de seguridad implementadas (o ausentes) en el sitio objetivo.

► Captura del laboratorio

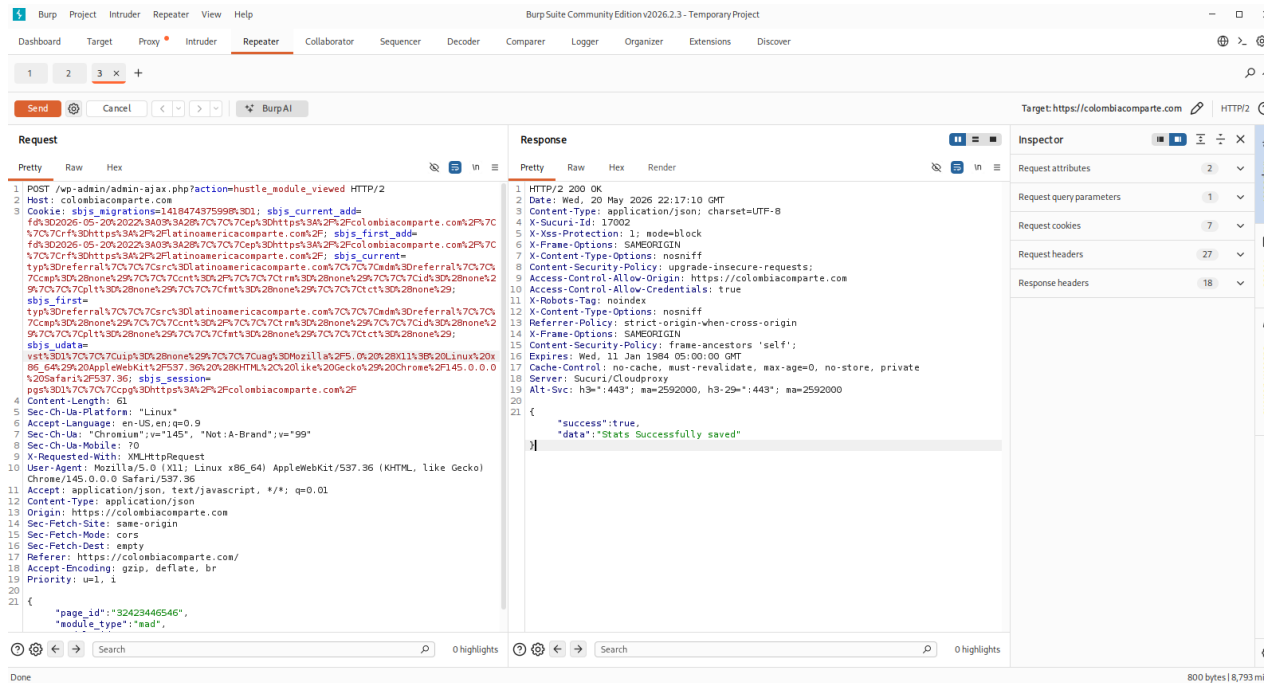


Figura 4: Repeater — petición POST a `colombiacomparte.com/wp-admin/admin-ajax.php?action=hustle_module_viewed` con su respuesta HTTP/2 200 OK. La respuesta JSON confirma `{\"success\":true,\"data\":{\"Stats Successfully saved\"}}`. Se observan las cabeceras de seguridad implementadas por el servidor (Sucuri-/Cloudproxy).

► Análisis de cabeceras de seguridad en la respuesta

Cabecera	Presente	Valor / Observación
X-Xss-Protection	✓	1; mode=block
X-Frame-Options	✓	SAMEORIGIN
X-Content-Type-Options	✓	nosniff
Content-Security-Policy	~	Solo upgrade-insecure-requests
Referrer-Policy	✓	strict-origin-when-cross-origin
Access-Control-Allow-Origin	~	Solo dominio propio
X-Robots-Tag	✓	noindex
Server	!	Sucuri/Cloudproxy (revelado)
Cache-Control	✓	no-cache, must-revalidate, no-store
Expires	!	Wed, 11 Jan 1984 (fecha antigua)

Hallazgos:

1. La cabecera **Server: Sucuri/Cloudproxy** revela el WAF utilizado. Conocer la tecnología de protección permite a un atacante buscar técnicas de bypass específicas para Sucuri.
2. La política CSP solo contiene **upgrade-insecure-requests**, sin directivas **script-src** ni **default-src**, lo que la hace prácticamente ineficaz contra ataques XSS.
3. El endpoint **hustle_module_viewed** acepta cookies de sesión (**sbjs_migrations**, **sbjs_current**, **sbjs_session**) en texto plano dentro de la petición POST, exponiendo datos de seguimiento del usuario.

Resumen de Hallazgos

Hallazgo	Nivel	Módulo	Detalle
CDN externo sin SRI	Medio	Proxy / Repeater	Google Fonts sin integridad verificable
WordPress expuesto	Medio	HTTP History	/wp-admin/admin-ajax.php accesible
Plugin Slider Revolution	Alto	HTTP History	Historial de CVEs críticos
CSP insuficiente	Medio	Repeater	Solo upgrade-insecure-requests
Server banner revelado	Medio	Repeater	Sucuri/Cloudproxy expuesto
Cookies de sesión en POST	Medio	Repeater	sbjs_* sin cifrado adicional
Infraestructura separada	Info	HTTP History	IPs distintas para dominios hermanos

Conclusión

El análisis mediante Burp Suite sobre **latinoamericacomparte.com** y su dominio hermano **colombia-comparte.com** permitió identificar los siguientes aspectos clave:

1. **Uso de WordPress sin hardening visible:** La exposición de `/wp-admin/admin-ajax.php` y del endpoint de Slider Revolution sugiere que el CMS no ha sido configurado para ocultar su estructura interna, facilitando la fase de reconocimiento de un atacante.
2. **WAF Sucuri activo pero con CSP débil:** La presencia de Sucuri/Cloudproxy proporciona una capa de protección perimetral, pero la política CSP incompleta deja abierto el vector de XSS desde el código de la propia aplicación.
3. **Dependencias de CDN externas:** La carga de fuentes desde Google Fonts sin SRI introduce un riesgo de cadena de suministro que podría ser explotado en un escenario de compromiso del CDN.
4. **Valor del Repeater:** El módulo Repeater demostró ser indispensable para analizar con detalle las cabeceras de respuesta y confirmar la implementación (o ausencia) de controles de seguridad HTTP, sin necesidad de ejecutar ataques activos.

Todos los análisis se realizaron en modo pasivo y observacional sobre el tráfico generado por la propia navegación del estudiante, en cumplimiento estricto de la **Ley 1273 de 2009** de Colombia y de los principios éticos del pentesting responsable.